ОТЧЁТ ОБ АУДИТЕ БЕЗОПАСНОСТИ САЙТА

Пассивная проверка OWASP ZAP 2.17.0 | Локальная и рабочая версии | 2 ноября 2026 г.

01 / Краткое резюме

Отчёт основан на двух результатах OWASP ZAP Baseline, предоставленных владелицей сайта. Ручная эксплуатация уязвимостей и независимая проверка не проводились. На рабочем сайте не обнаружено предупреждений высокого уровня. Остальные предупреждения указывают на настройки и возможности усиления защиты, но не доказывают взлом или наличие эксплуатируемых уязвимостей. В первую очередь следует проверить обработчик контактной формы и политику CORS.

Рабочий сайт: 0 высоких, 4 средних, 2 низких и 5 информационных категорий предупреждений; 41 адрес. Локальная версия: 0 высоких, 6 средних, 6 низких и 2 информационные категории; 40 адресов. Это категории, а не число подтверждённых уязвимостей. ZAP пометил 81% ответов рабочего сайта как медленные, но одного измерения недостаточно для оценки производительности у реальных пользователей.

02 / Область проверки и методика

OWASP ZAP 2.17.0 в режиме Baseline проверил локальную статическую копию и опубликованный сайт. Анализировались HTTP-ответы, заголовки, ссылки и найденные ресурсы. Локальный сервер Python не выполняет реальный обработчик /api/contact и возвращает HTTP 501. В рабочей среде обнаружен 41 адрес (около 97% запросов GET и 2% POST). Активная эксплуатация, полный анализ исходного кода, проверка аутентификации, нагрузочное тестирование и доставка почты не проверялись.

03 / Результаты и защитные меры

F01 | Нет токена anti-CSRF в форме | СРЕДНИЙ / ПРОВЕРИТЬ

ZAP обнаружил форму POST /api/contact без скрытого CSRF-токена (два случая). CSRF — принуждение браузера к нежелательному действию от имени пользователя, особенно при автоматической передаче сессионных данных. Для общедоступной анонимной формы отсутствие токена само по себе не доказывает уязвимость; актуальнее могут быть спам и злоупотребление ресурсами.

Проверить использование сессий и cookie на сервере; при необходимости проверять Origin/Referer; применять токены для аутентифицированных операций; ограничивать частоту запросов, проверять поля на сервере, использовать honeypot как дополнительную защиту и журналировать аномалии. Тестировать на стенде без реальной отправки писем.

F02 | CSP допускает unsafe-inline в style-src | СРЕДНИЙ / НАСТРОЙКА ПОДТВЕРЖДЕНА

Политика содержит style-src 'self' 'unsafe-inline' https://fonts.googleapis.com. CSP ограничивает загрузку ресурсов браузером; unsafe-inline разрешает встроенный CSS и ослабляет защиту от внедрения стилей. Это не подтверждённая XSS-уязвимость. Хеши скриптов и script-src-attr none уже усиливают защиту.

Провести инвентаризацию встроенных стилей; перенести их во внешние CSS или применить хеши/nonces; сначала протестировать Content-Security-Policy-Report-Only; сохранить ограничения скриптов и frame-ancestors none. Проверить консоль и внешний вид сайта.

F03 | CORS разрешает любой источник | СРЕДНИЙ / ЗАВИСИТ ОТ КОНТЕКСТА

ZAP обнаружил Access-Control-Allow-Origin: * в публичных HTML, CSS, robots.txt и sitemap.xml. CORS определяет, может ли JavaScript с другого источника читать ответы браузера. Для намеренно открытых ресурсов символ * часто допустим и не доказывает утечку частных данных. Ответы API требуют отдельной проверки.

Проверить правила Cloudflare/Workers для каждого маршрута; убрать ненужный CORS; ограничить источники для API; не раскрывать конфиденциальные данные; проверить preflight и ответы об ошибках; не сочетать произвольные источники с учётными данными.

F04 | Нет SRI у внешних таблиц стилей | СРЕДНИЙ / УСИЛЕНИЕ ЗАЩИТЫ

Ссылки на CSS Google Fonts не имеют атрибута integrity. SRI сравнивает внешний ресурс с ожидаемым хешем. CSS Google Fonts может различаться между браузерами, поэтому фиксированный хеш способен нарушить загрузку шрифтов. Признаков компрометации нет.

По возможности размещать нужные шрифты и CSS на собственном сервере; сократить число семейств; использовать integrity и crossorigin для стабильных версионированных ресурсов. Проверить отображение после изменений.

F05 | Отсутствует COEP | НИЗКИЙ / НЕОБЯЗАТЕЛЬНО

Заголовок Cross-Origin-Embedder-Policy отсутствует в трёх HTML-ответах. COEP вместе с COOP может обеспечивать изоляцию источников. Не каждому сайту это нужно; require-corp может блокировать внешние ресурсы.

Определить необходимость изоляции; проверить совместимость внешних зависимостей; включать require-corp или credentialless только после обоснования и тестирования.

F06 | Нет HSTS в двух ответах API | НИЗКИЙ / ПРОВЕРИТЬ

Заголовок Strict-Transport-Security отсутствует на /api/ и /api/contact, хотя главная страница его отправляет. HSTS предписывает браузеру использовать HTTPS. Отсутствие заголовка в отдельных ответах не доказывает передачу данных по HTTP.

Проверить Cloudflare/Workers и ответы об ошибках; согласовать политику HSTS и HTTPS; проверить перенаправления HTTP→HTTPS и последствия includeSubDomains.

04 / Информационные предупреждения

Пять информационных категорий касаются безобидного комментария в contact-confirmation.js (сработало слово “from”), запрета кеширования, повторной проверки Cache-Control, кеширования

публичных ресурсов и ответов, требующих валидации. Сами по себе они не свидетельствуют об инциденте. Локальный сервер Python не воспроизводит заголовки Cloudflare и Workers; его предупреждения об отсутствии защиты от clickjacking, nosniff и Permissions-Policy, а также раскрытии версии Python нельзя автоматически переносить на рабочий сайт. Ноль ложных срабатываний в ZAP означает лишь, что их никто не отметил вручную.

05 / Приоритетный план исправлений

P1 (1–3 дня): проверить /api/contact — валидацию, Origin, ограничение частоты, антиспам и зависимости от сессий; проверить CORS в API и ответах об ошибках. P2 (1–2 недели): сократить или локально разместить Google Fonts; постепенно отказаться от unsafe-inline после проверки Report-Only; согласовать HSTS. P3 (по необходимости): решить, нужен ли COEP. Постоянно: повторять ZAP Baseline после изменений, сохранять датированные доказательства, измерять LCP/INP/CLS, обновлять зависимости, не хранить секреты в репозитории и документировать остаточные риски.

06 / Технический словарь

Endpoint — HTTP-маршрут, например /api/contact. HTTP 2xx/3xx/4xx/5xx — успех/перенаправление/ошибка клиента/ошибка сервера. GET запрашивает данные; POST обычно отправляет данные. HTTP-заголовок — метаданные ответа. CSP — политика загрузки ресурсов. CSRF — подделка межсайтовых запросов. CORS — разрешения на чтение между источниками. SRI — хеш целостности внешнего ресурса. HSTS — принудительный HTTPS в браузере. COEP/COOP/CORP — политики изоляции источников. X-Frame-Options/frame-ancestors — защита от clickjacking. nosniff — запрет определения MIME по содержимому. Cache-Control — управление кешированием. Ложное срабатывание — неприменимое предупреждение после проверки; остаточный риск — риск после внедрения мер.

07 / Источники и ограничения

Исходные данные: отчёты OWASP ZAP Baseline для локального и рабочего сайта от 2 ноября 2026 г., а также HTTP-заголовки, предоставленные владелицей. Проверяемые технические источники: OWASP ZAP Baseline Scan, OWASP CSRF Prevention и CSP Cheat Sheets, MDN CORS/SRI/HSTS/COEP, OWASP Secure Headers. Наличие указанных заголовков в предоставленных материалах подтверждено с высокой уверенностью; оценка последствий имеет умеренную уверенность без исходного кода сервера, конфигурации Cloudflare, функциональных тестов и журналов. Это интерпретация пассивного автоматического анализа, а не сертификация или полноценный пентест.

https://www.zaproxy.org/docs/docker/baseline-scan/

https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html

https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html

https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CORS

https://developer.mozilla.org/en-US/docs/Web/Security/Defenses/Subresource_Integrity

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Strict-Transport-Security

https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/Cross-Origin-Embedder-Policy

https://owasp.org/www-project-secure-headers/